

# 信息安全基础

## 第一章 密码学基础

对称加密使用同一个密钥加密和解密，典型算法是 AES，速度快，适合加密大块数据，难点是密钥的安全分发。

非对称加密使用公钥和私钥两个密钥，典型算法是 RSA 和椭圆曲线加密，公钥可以公开分发，私钥必须严格保密。

实践中通常采用混合加密：用非对称加密协商对称密钥，之后的数据传输使用对称加密，HTTPS 正是这一方案。

## 第二章 哈希与数字签名

哈希函数把任意长度输入映射为固定长度输出，具有单向性和抗碰撞性。MD5 和 SHA-1 已被证明不安全，应使用 SHA-256 及以上算法。

数字签名的过程是发送方用私钥对内容摘要签名，接收方用公钥验证，从而保证完整性和不可抵赖性。

数字证书由 CA 签发，将公钥与持有者身份绑定，是 HTTPS 信任体系的基础。

### 第三章 常见 Web 攻击与防御

SQL 注入通过在输入中拼接 SQL 片段篡改查询语义，防御的核心是使用参数化查询和预编译语句，并对输入做校验。

XSS 跨站脚本攻击把恶意脚本注入页面在用户浏览器执行，防御手段包括输出转义、内容安全策略 CSP 和 HttpOnly Cookie。

CSRF 跨站请求伪造借用用户已登录的身份发起非法请求，常用防御是 CSRF Token 和 SameSite Cookie 属性。

## 第四章 认证与授权

认证解决你是谁的问题，授权解决你能做什么的问题，两者相互独立。

JWT 由头部、载荷和签名三部分组成，服务端验证签名即可信任载荷，适合无状态的分布式场景，但签发后无法主动作废，需要配合黑名单或短有效期。

密码绝不能明文存储，应使用 bcrypt、Argon2 等慢哈希加盐处理，即使数据库泄露也难以还原原始密码。